



คู่มือการตรวจประเมินระดับการรักษา ความมั่นคงปลอดภัยไซเบอร์

(Cybersecurity Technical
Assessment Matrix Plus: CTAM+)

พ.ศ. 2569



ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร
สำนักงานปลัดกระทรวงสาธารณสุข

แนวทางการประเมินการรักษาความมั่นคงปลอดภัยไซเบอร์

เกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ (CTAM+ : Cybersecurity Technical Assessment Matrix Plus) ปี 2569

1. หน่วยงานดำเนินการให้ระบบเครือข่ายคอมพิวเตอร์และสารสนเทศตามเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ และประเมินตนเอง หรือให้ผู้เชี่ยวชาญที่เป็นผู้ตรวจประเมิน (หากเป็นเอกชนต้องมีใบรับรองมาตรฐาน)
2. หน่วยงานส่งผลยืนยันผลการประเมินพร้อมหลักฐานให้คณะทำงานควบคุมคุณภาพการตรวจประเมินความมั่นคงปลอดภัยไซเบอร์ระดับเขตสุขภาพ หรือ คณะทำงานควบคุมคุณภาพการตรวจประเมินความมั่นคงปลอดภัยไซเบอร์ระดับสำนักงานปลัดกระทรวงสาธารณสุข ที่อีเมล cyberaudit@moph.go.th หรือช่องทางอื่น ตามที่ ศทส.สป.สธ. กำหนดเพิ่มเติม ทุกวันพฤหัสบดี
3. ศูนย์เทคโนโลยีสารสนเทศและการสื่อสารจะยืนยันผลการประเมินของหน่วยงานทุกศุกร์โดยแสดงผลที่ <https://ict.moph.go.th/th/extension/1763>
4. เกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ (CTAM+: Cybersecurity Technical Assessment Matrix Plus)

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
1	Backup : การสำรองข้อมูลเก็บไว้ที่อื่น เพื่อให้สามารถใช้เพื่อคืนข้อมูลเดิมหลังจากเหตุการณ์ข้อมูลสูญหาย สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการสำรองข้อมูลอย่างน้อยวันละ 1 ครั้ง และสามารถย้อนหลังได้ 7 วัน เป็นอย่างน้อยตามมาตรฐาน โดยจัดเก็บบนระบบ Logical HDD หรือ Physical HDD และ จัดเก็บ Backup ในรูปแบบ 3-2-1 1. สำเนาข้อมูลไว้บนระบบ 3 ชุด 2. สำเนาข้อมูลไว้บนเทคโนโลยีต่างกัน 2 ชุด 3. สำเนาข้อมูลไว้แบบ Offline หรือ Offsite หรือ Cloud 1 ชุด	1. คู่มือการปฏิบัติงาน (options) 2. รายงานผลการดำเนินการการสำรองข้อมูล 3. รายการระบบที่สำรองข้อมูล (ภาพหลักฐาน หรือเอกสารประกอบอื่นๆ)
2	Antivirus Software : โปรแกรมป้องกันไวรัส หรือ แอนติไวรัส คอยตรวจจับป้องกัน และกำจัดโปรแกรมคุกคามทางคอมพิวเตอร์ หรือมัลแวร์ สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการติดตั้ง Anti-Virus หรือ EDR หรือ XDR บนเครื่องคอมพิวเตอร์ของระบบที่สำคัญ 1. Review Alert Report 2. Update Program Anti-Virus, EDR/XER 3. Schedule Update Database Signature	1. คู่มือการติดตั้ง (options) 2. ผลการดำเนินการติดตั้ง 3. รายการเครื่องคอมพิวเตอร์ของระบบที่สำคัญ ที่ทำการติดตั้ง (ภาพหลักฐานของเครื่องที่ติดตั้ง หรือเอกสารประกอบอื่นๆ)

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
3	Access Control (Public และ Private) : การควบคุมอุปกรณ์หรือการเข้าถึงระบบผ่านทางช่องทาง Public/Private ทั้งภายในประเทศและต่างประเทศ สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการควบคุม Policy การเข้าถึงระบบที่สำคัญทั้งทาง Public และ Private 1. Open Port Access จากภายนอกเท่าที่จำเป็น เช่น HTTPS (443) 2. IP Address Filter กำหนดขอบเขตการใช้งาน IP Address ที่สามารถเข้าใช้งานในระบบได้ เช่น IP Location, Geometric 3. Enable IDS/IPS 4. ใช้ระบบ VPN (Virtual Private Network) สำหรับการเข้าถึง Server/Application ภายในผ่านโปรโตคอล IPsec/SSL 5. มีการแบ่งโซน Network ภายใน รวมถึงมี Firewall กันระหว่างโซนภายในที่สำคัญ 6. User Access Accounts กำหนดสิทธิการใช้งานเท่าที่จำเป็น เช่น Role Base / Group Base 7. User Password Policy กำหนดการใช้งานพาสเวิร์ด เช่น กำหนดความยาวอย่างน้อย 12 ตัวอักษร, Hash MD5, SHA-256 8. Time Sync 9. Change Default Accounts 10. Review Privilege Accounts 11. Review Logs Access 12. Feeds IOC (Option)	1. คู่มือการตั้งค่าอุปกรณ์ Firewall (options) 2. รายงานหรือเอกสารผลการดำเนินการตั้งค่าอุปกรณ์ Firewall โดยมีรายละเอียด ตามเงื่อนไขการควบคุม 12 ข้อ 3. ตารางกำหนดสิทธิแต่ละอุปกรณ์ (options) หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
4	Privileged Access Management (PAM) : การรักษาความปลอดภัยของข้อมูล ติดตาม ตรวจสอบ และป้องกันการใช้สิทธิ์การเข้าถึงทรัพยากรที่สำคัญในระดับสูง สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการควบคุมการเข้าถึงระบบโดยใช้งานสิทธิ์ระดับ Least Privilege ดังนี้ 1. ดำเนินการ Disable Administrator / Root / Admin 2. มีการกำหนด Role-base access ในการเข้าถึงระบบเท่าที่มีจำเป็น 3. มี Access Rights Matrix ของระบบ 4. มีการตั้ง Password อย่างน้อย 12 ตัว (ตัวอักษรใหญ่, เล็ก, อักขระพิเศษ, ตัวเลข) 12 , มีการเข้ารหัส Password MD5,SHA-256 5. Expire Sessions Time out 6. Review Privilege Accounts 7. Review กิจกรรมผู้ใช้งานในระบบ	1. คู่มือการตั้งค่าระบบที่สำคัญ (options) 2. ผลการดำเนินการตั้งค่าการกำหนดสิทธิ 3. ตารางกำหนดสิทธิระบบที่สำคัญ เทียบกับระบบจริง (options) หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
5	Business Continuity Plan (BCP) Disaster Recovery Plan (DRP) : แผนที่กำหนดแนวทางการดำเนินการของหน่วยงานเมื่อเกิดสภาวะวิกฤตหรือภัยต่าง ๆ ที่ส่งผลให้กระบวนการทำงานของหน่วยงานหยุดชะงัก เพื่อให้สามารถกลับมาดำเนินการได้อย่างต่อเนื่อง สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการทดสอบ Business Continuity Plan (BCP) และ Disaster Recovery Plan (DRP) อย่างน้อยปีละ 1 ครั้ง และ มีการจัดทำรายงานถึง ขั้นตอนการดำเนินการที่ชัดเจนรวมถึงระยะเวลาดำเนินการและผู้ที่เกี่ยวข้องในการดำเนินงานดังนี้ 1. การบริหารจัดการความเสี่ยง (Risk Management) 2. การบริการจัดการด้าน Resource (Resource Management) 3. การวางแผนความต่อเนื่องจากธุรกิจที่เกิดขึ้น (Business Continuity Planning) 4. การทดสอบ (Testing) 5. การปรับปรุงและแก้ไข (Review & Update)	1. เอกสารแผน Business Continuity Plan (BCP) 2. เอกสารแผน Disaster Recovery Plan (DRP) 3. รายงานผลการทดสอบตามที่กำหนด หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
6	OS Patching : การซ่อมแซมจุดบกพร่องของระบบปฏิบัติการ (OS) หรือปรับปรุงระบบปฏิบัติการให้ทันสมัย และเพิ่มเติมความสามารถในการใช้งานหรือประสิทธิภาพให้ดีขึ้น สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการอัปเดต Security Patching 1. Firewall patching (Firmware) 2. Operation patching 3. Application patching 4. Software patching 5. Change Management	1. คู่มือการอัปเดตรวมทั้ง Hardware และ Software (options) 2. ผลการดำเนินงาน หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
7	Multi-Factor Authentication (2FA) : การยืนยันตัวตน 2 ชั้น เป็นการเข้าสู่ระบบบัญชีแบบหลายขั้นตอนที่กำหนดให้ผู้ใช้อัปโหลดข้อมูลเพิ่มเติมนอกเหนือจากรหัสผ่าน สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการใช้งานระบบ Multi-Factor Authentication (2FA) เพื่อยืนยันตัวตน 2 ชั้นในการเข้าถึงระบบต่างๆ สำหรับ Admin ที่ใช้งานระบบดังนี้ 1. การ Login แบบ Multi-factor ไปยังระบบ VPN Access 2. การ Login แบบ Multi-factor ไปยังอุปกรณ์ Network 3. การ Login แบบ Multi-factor ไปยังอุปกรณ์ Security 4. การ Login แบบ Multi-factor ไปยัง Hypervisor 5. การ Login แบบ Multi-factor ไปยัง Operating system	1. คู่มือการติดตั้งและตั้งค่าการใช้งาน (options) 2. รายละเอียดของระบบที่ใช้ และผลการดำเนินงาน (แสดงรูปภาพหน้าจอ ของระบบ) หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
8	Web Application Firewall (WAF) : ระบบป้องกันการโจมตีทางไซเบอร์สำหรับเว็บแอปพลิเคชันโดยเฉพาะ เพื่อป้องกันการโจมตีไปยังระบบเว็บแอปพลิเคชันของหน่วยงาน สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการใช้งาน Web Application Firewall (WAF) กรณีที่มีระบบเป็น Web Application เพื่อป้องกันการโจมตีตามมาตรฐาน OWASP Top 10 ได้เป็นอย่างดีตามรายละเอียด 1. Review Attack Report 2. Add Source IP Blocklists	1. คู่มือการใช้งานและตั้งค่าการใช้งานของ WAF (options) 2. ผลการดำเนินการติดตั้ง หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
9	Log Management : การจัดเก็บข้อมูลจราจรทางคอมพิวเตอร์ สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีระบบการจัดเก็บ Log อินเทอร์เน็ต และคอมพิวเตอร์ ตาม พ.ร.บ. คอมฯ อย่างน้อย 90 วัน 1. System Logs 2. Access Logs 3. Authentication Logs 4. Authorization Logs 5. Error Logs 6. Applications Logs	1. คู่มือการติดตั้งและตั้งค่าการใช้งานระบบ Log Management (options) 2. รายงานผล Log ย้อนหลัง วันที่ 90 ของ Log ที่เก็บ หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
10	Security Information & Event Management (SIEM) : ระบบที่ใช้ในการจัดการกับ Log และ Event ต่าง ๆ ที่คอยทำหน้าที่วิเคราะห์หาความเชื่อมโยงของ Event ต่าง ๆ ที่เกี่ยวข้องกับความปลอดภัยทั้งหมด ไปจนถึงการ Alert ระบุตำแหน่งของภัยคุกคามให้ทราบ เมื่อมี Event ที่ผิดปกติทำให้สามารถป้องกัน และตอบสนองภัยคุกคามได้อย่างรวดเร็ว สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีระบบ SIEM หรือระบบวิเคราะห์ภัยคุกคามทางไซเบอร์ เพื่อนำมาวิเคราะห์พฤติกรรมของ Cyber Attack บนระบบที่ให้บริการทั้งระดับ Infrastructure และ Operating system (OS) ดังนี้ 1. ตรวจสอบและแจ้งเตือนการบุกรุกที่เข้าถึงระบบเครือข่าย การพยายาม Brute force Login เข้าระบบ และ การ Scan port (port scanning) 2. Malware-Virus Detection ตรวจสอบและแจ้งเตือน Malware หรือ Virus จากพฤติกรรมต่างๆ ที่เกิดขึ้นหรือจาก signature 3. Blacklist IP การตรวจสอบและแจ้งเตือนการเข้าถึง IP Address ที่เป็น Blacklist และระบุการเปิด connection ได้ 4. Unauthorized Access การตรวจสอบการเข้าถึงข้อมูลหรือระบบที่ไม่ได้รับอนุญาต หรือไม่มีสิทธิ์เข้าถึงระบบ 5. DDoS Attack การตรวจสอบพฤติกรรมการโจมตีในรูปแบบของ DDoS ได้ ทั้งภายนอกและภายใน 6. Data Breaches การตรวจสอบและแจ้งเตือนการละเมิดการเข้าถึงข้อมูลที่สำคัญของระบบ ที่ไม่อนุญาตให้เข้าถึง	1. รายละเอียดของระบบ SIEM และระบบหรืออุปกรณ์ที่ทำการส่ง LOG 2. คู่มือตั้งค่าการใช้งานระบบ SIEM 3. รายงานผลที่เกิดขึ้นจากระบบ SIEM ตรวจสอบได้ หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
11	Vulnerability Assessment (VA Scan) : การตรวจสอบช่องโหว่ของระบบ เพื่อให้ทราบถึงความเสี่ยง จุดอ่อน และระดับความรุนแรง ของผลกระทบที่อาจเกิดขึ้นจากการถูกโจมตีระบบข้อมูลและการโจมตีทางไซเบอร์ สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการดำเนินการ Vulnerability Assessment (VA Scan) อย่างน้อยปีละ 1 ครั้ง โดยจะต้องดำเนินการแก้ไข CVE และช่องโหว่ต่างๆ ที่เกิดขึ้นโดยให้ความสำคัญกับความเสี่ยงระดับ Critical, High เป็นลำดับแรก โดยมีการดำเนินการดังนี้ 1. Review Vulnerability Assessment Report 2. จัดลำดับความสำคัญ ความเสี่ยงระดับ Critical, High, Medium ,Low กำหนดระยะเวลาในการแก้ไขช่องโหว่ 3. การจัดการความเสี่ยง 3.1 ยอมรับความเสี่ยง (Risk Acceptance) 3.2 หลีกเลี่ยงความเสี่ยง (Risk Avoidance) 3.3 ลดความเสี่ยง (Risk Mitigation) 3.4 ถ่ายโอนความเสี่ยง (Risk Transfer)	1. รายงานการผลการดำเนินการตรวจสอบช่องโหว่ของระบบที่สำคัญ โดยรายละเอียดอย่างน้อยต้องประกอบด้วยผลสรุปสำหรับผู้บริหาร รายละเอียดของช่องโหว่ที่ตรวจพบพร้อมแนวทางการแก้ไข หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
12	Information Asset Inventory and System Termination: สำรวจและปิดระบบงานที่ไม่ได้ใช้งานเพื่อป้องกันการเข้าถึงข้อมูล สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการสำรวจและจัดทำ Asset inventory ระบบงานสารสนเทศทั้งหมด พร้อมทั้งตรวจสอบระบบงานที่ไม่มีความจำเป็นต้องใช้งานแล้วให้ดำเนินการปิดการใช้งานระบบงานดังกล่าว	1. Asset inventory ระบบงานสารสนเทศทั้งหมด 2. รายละเอียดของระบบงาน สถานะการใช้งานระบบงาน หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
13	Software Update or Software Patching: อัปเดตซอฟต์แวร์หรือแพตช์ ด้านความปลอดภัย สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการอัปเดตซอฟต์แวร์หรือแพตช์ ด้านความปลอดภัยของระบบที่สำคัญ เช่น HIS	1. คู่มือการอัปเดตซอฟต์แวร์หรือแพตช์ ด้านความปลอดภัย (options) 2. ผลการดำเนินงาน หรือ รายงานการอัปเดต Patching ของระบบ หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
14	Network Segmentation: มีการแบ่งแยกเครือข่ายระบบสำคัญ ออกจากเครือข่ายระบบอื่น เพื่อจำกัดขอบเขตความเสียหายหากเกิดเหตุการณ์ทางไซเบอร์ สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการแบ่งแยกเครือข่าย (Segmentation) ระหว่างระบบสำคัญ (Critical Systems) และระบบอื่น ๆ เช่น (Guest Network, User Network) โดยมีการใช้ Firewall หรือ Access Control List (ACL) ในการควบคุมการเข้าถึงระหว่าง Segment	1. แผนผังเครือข่าย (Network Diagram) ที่แสดงการแบ่งแยก 2. การตั้งค่า Firewall/ACL ที่แสดงการควบคุมการเข้าออกระหว่าง Segment หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ลำดับ	ประเด็นการประเมิน	รายละเอียดการประเมิน	เอกสารประกอบการประเมิน
15	Licensed Software: มีการใช้ซอฟต์แวร์ถูกลิขสิทธิ์และมีการจัดการทรัพย์สินซอฟต์แวร์ (Software Asset Management - SAM) สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการใช้ซอฟต์แวร์ถูกลิขสิทธิ์สำหรับระบบงานและเครื่องคอมพิวเตอร์ที่สำคัญทั้งหมด และมีการจัดทำรายการทรัพย์สินซอฟต์แวร์ รวมถึงการตรวจสอบสถานะใบอนุญาต (License)	- รายการทรัพย์สินซอฟต์แวร์ (Software Asset Inventory) - หลักฐานการซื้อ/ใบอนุญาตซอฟต์แวร์ (License Proof/Agreement) - รายงานการตรวจสอบการใช้ซอฟต์แวร์ หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
16	Penetration Testing: การทดสอบการเจาะระบบเพื่อให้ทราบถึงจุดอ่อนหรือช่องโหว่ของระบบงาน สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการทำ Penetration Testing ของ Web Application หรือระบบงานอื่น ตามความเหมาะสมในรูปแบบของ Gray box หรือ Black box อย่างน้อยปีละ 1 ครั้ง และดำเนินการแก้ไขโดยจะต้องไม่มีช่องโหว่ระดับ Severity Critical , High เกิดขึ้นและไม่มีช่องโหว่ที่เกิดขึ้นตามมาตรฐาน OWASP TOP10	รายงานการทำ Penetration Testing โดยรายละเอียดอย่างน้อยต้องประกอบด้วยผลสรุปสำหรับผู้บริหาร รายละเอียดของช่องโหว่ที่ตรวจพบพร้อมแนวทางการแก้ไข หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้
17	Cybersecurity & PDPA Policy and Personnel Development: มีนโยบายด้านการรักษาความมั่นคงปลอดภัยไซเบอร์และการคุ้มครองข้อมูลส่วนบุคคล (PDPA) รวมถึงมีการส่งเสริมให้เกิดการพัฒนาบุคลากรด้านดังกล่าว สถานะการดำเนินงานในปัจจุบัน ☐ มี ☐ ไม่มี	มีการจัดทำนโยบายด้านความมั่นคงปลอดภัยไซเบอร์ และ PDPA ที่เป็นลายลักษณ์อักษรและประกาศใช้อย่างเป็นทางการ และมีการจัดอบรม/พัฒนาบุคลากรให้มีความรู้ความเข้าใจในด้ดังกล่าวอย่างน้อยปีละ 1 ครั้ง	- เอกสารนโยบายด้านความมั่นคงปลอดภัยไซเบอร์ - เอกสารนโยบาย PDPA - รายงาน/หลักฐานการจัดอบรมบุคลากร (เช่น ตารางการอบรม, รายชื่อผู้เข้าร่วม) หมายเหตุ : เอกสารประกอบสามารถใช้ภาพหลักฐาน หรือเอกสารที่เกี่ยวข้องที่บ่งชี้ในแต่รายการการประเมินได้

ตัวชี้วัดกระทรวงสาธารณสุข

แผนที่ 9	การพัฒนาระบบบริการสุขภาพดิจิทัล
โครงการที่ 21	โครงการยกระดับความมั่นคงปลอดภัยไซเบอร์
ระดับการแสดงผล	จังหวัด/เขต/ประเทศ
ชื่อตัวชี้วัด	ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง
คำนิยาม	1. หน่วยงาน หมายถึง โรงพยาบาลสังกัดสำนักงานปลัดกระทรวงสาธารณสุข ได้แก่ โรงพยาบาลศูนย์/ทั่วไป/ชุมชนที่เปิดให้บริการแล้ว และ สำนักงานสาธารณสุขจังหวัด และ สำนักงานเขตสุขภาพ ที่ 1-12 2. มาตรฐานความมั่นคงปลอดภัยไซเบอร์ หมายถึง เกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ (Cybersecurity Technical Assessment Matrix Plus: CTAM+) 3. ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง หมายถึง ผลการประเมินผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ (CTAM+) ตามที่กำหนดครบทุกข้อ ดังนี้ 1) Backup 2) Antivirus Software 3) Access Control (Public และ Private) 4) Privileged Access Management (PAM) 5) Business Continuity Plan (BCP) และ Disaster Recovery Plan (DRP) 6) OS Patching 7) Multi-Factor Authentication (2FA) 8) Web Application Firewall (WAF) 9) Log Management 10) Security Information & Event Management (SIEM) 11) Vulnerability Assessment (VA Scan) 12) สำรองและปิดระบบงานที่ไม่ได้ใช้งานเพื่อป้องกันการเข้าถึงข้อมูล 13) อัปเดตซอฟต์แวร์หรือแพตช์ ด้านความปลอดภัย 14) Network Segmentation 15) ใช้ซอฟต์แวร์ถูกลิขสิทธิ์

16) Penetration Testing

17) มีนโยบายด้านการรักษาความมั่นคงปลอดภัยไซเบอร์และการคุ้มครอง

ข้อมูลส่วนบุคคล รวมถึง การส่งเสริมให้เกิดการพัฒนาบุคลากรด้านดังกล่าว

เกณฑ์เป้าหมาย : ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง

ปีงบประมาณ 69	ปีงบประมาณ 70
ร้อยละ 100 ของ หน่วยงานผ่าน เกณฑ์ฯ ระดับสูง	ร้อยละ 100 ของ หน่วยงานผ่าน เกณฑ์ฯ ระดับสูง

วัตถุประสงค์

1. เพื่อให้หน่วยงานมีความพร้อมรับมือเหตุการณ์ฉุกเฉินทางคอมพิวเตอร์ ด้วยระบบป้องกัน ตรวจสอบ วิเคราะห์ และโต้ตอบต่อภัยคุกคามทางไซเบอร์
2. เพื่อลดความรุนแรงของผลกระทบกรณีหน่วยงานถูกคุกคามทางไซเบอร์ที่ส่งผลต่อการให้บริการ ประชาชน และอาจส่งผลต่อการคุ้มครองข้อมูลส่วนบุคคล
3. เพื่อลดปัจจัยเสี่ยงของโอกาสเกิดช่องโหว่ภัยคุกคามทางไซเบอร์
4. เพื่อให้ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์ของหน่วยงานโครงสร้างพื้นฐานสำคัญทางสารสนเทศด้านสาธารณสุข (HealthCERT) ได้รับการประสานงานอย่างรวดเร็ว และโต้ตอบต่อ ภัยคุกคามทางไซเบอร์ได้ทันเวลา

ประชากรกลุ่มเป้าหมาย -

วิธีการจัดเก็บข้อมูล

1. หน่วยงานดำเนินการให้ระบบเครือข่ายคอมพิวเตอร์และสารสนเทศตามเกณฑ์มาตรฐานความ มั่นคงปลอดภัยไซเบอร์ และประเมินตนเอง หรือให้ผู้เชี่ยวชาญที่เป็นผู้ตรวจประเมิน (หากเป็นเอกชนต้องมี ใบรับรองมาตรฐาน)
2. หน่วยงานส่งผลยืนยันผลการประเมินพร้อมหลักฐานให้คณะทำงานควบคุมคุณภาพการตรวจ ประเมินความมั่นคงปลอดภัยไซเบอร์ระดับเขตสุขภาพ หรือ คณะทำงานควบคุมคุณภาพการตรวจประเมิน ความมั่นคงปลอดภัยไซเบอร์ระดับสำนักงานปลัดกระทรวงสาธารณสุข ที่อีเมล cyberaudit@moph.go.th ทุกวันพฤหัสบดี

3. ศูนย์เทคโนโลยีสารสนเทศและการสื่อสารจะยืนยันผลการประเมินของหน่วยงานทุกศุภกรโดยแสดง
ผลที่ <https://ict.moph.go.th/th/extension/1763>

แหล่งข้อมูล Cybersecurity Dashboard (<https://ict.moph.go.th/th/extension/1763>)

รายการข้อมูล 1A = หน่วยงานที่รักษาระดับมาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง

รายการข้อมูล 2B = หน่วยงานทั้งหมด (หน่วยงานตามที่กำหนดไว้ในคำนิยาม)

สูตรคำนวณตัวชี้วัด $(A/B) \times 100$

หมายเหตุ ทศนิยมตั้งแต่ .5 ขึ้นไปให้ปัดขึ้น

ระยะเวลาประเมินผล 12 เดือน

เกณฑ์การประเมิน :

รอบ 3 เดือน	รอบ 6 เดือน	รอบ 9 เดือน	รอบ 12 เดือน
โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์ มาตรฐานความมั่นคง ปลอดภัยไซเบอร์ ระดับสูง ไม่น้อยกว่า ร้อยละ 80	สำนักงานสาธารณสุข จังหวัด และสำนักงาน เขตสุขภาพ ผ่านเกณฑ์ มาตรฐานความมั่นคง ปลอดภัยไซเบอร์ ระดับสูง ไม่น้อยกว่า ร้อยละ 80	โรงพยาบาลชุมชน ผ่าน เกณฑ์มาตรฐานความ มั่นคงปลอดภัยไซเบอร์ ระดับสูง ไม่น้อยกว่า ร้อยละ 80	หน่วยงาน ผ่าน เกณฑ์มาตรฐาน ความมั่นคงปลอดภัย ไซเบอร์ระดับสูง ร้อยละ 100

วิธีการประเมินผล : ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร ตรวจสอบหลักฐาน และนำผลประเมิน เข้าสู่ Cybersecurity Dashboard ทุกสัปดาห์

เอกสารสนับสนุน : เกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ (Cybersecurity Technical Assessment Matrix Plus : CTAM+) เผยแพร่ที่เว็บไซต์ <https://cyber.moph.go.th/>

ตัวชี้วัดตรวจราชการกระทรวงสาธารณสุข

ยุทธศาสตร์

Governance Excellence

ชื่อตัวชี้วัด :

ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง

คำนิยาม :

1. หน่วยงาน หมายถึง โรงพยาบาลสังกัดสำนักงานปลัดกระทรวงสาธารณสุข ได้แก่ โรงพยาบาลศูนย์/ทั่วไป/ชุมชนที่เปิดให้บริการแล้ว และ สำนักงานสาธารณสุขจังหวัด และ สำนักงานเขตสุขภาพ ที่ 1-12

2. มาตรฐานความมั่นคงปลอดภัยไซเบอร์ หมายถึง เกณฑ์การประเมินระดับการรักษาความมั่นคงปลอดภัยไซเบอร์ (Cybersecurity Technical Assessment Matrix Plus: CTAM+)

3. ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง หมายถึง ผลการประเมินผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ (CTAM+) ตามที่กำหนดครบทุกข้อ ดังนี้

- 1) Backup
- 2) Antivirus Software
- 3) Access Control (Public และ Private)
- 4) Privileged Access Management (PAM)
- 5) Business Continuity Plan (BCP) และ Disaster Recovery Plan (DRP)
- 6) OS Patching
- 7) Multi-Factor Authentication (2FA)
- 8) Web Application Firewall (WAF)
- 9) Log Management
- 10) Security Information & Event Management (SIEM)
- 11) Vulnerability Assessment (VA Scan)
- 12) สำรวจและปิดระบบงานที่ไม่ได้ใช้งานเพื่อป้องกันการเข้าถึงข้อมูล
- 13) อัปเดตซอฟต์แวร์หรือแพตช์ ด้านความปลอดภัย
- 14) Network Segmentation
- 15) ใช้ซอฟต์แวร์กักกันภัยคุกคาม
- 16) Penetration Testing

17) มีนโยบายด้านการรักษาความมั่นคงปลอดภัยไซเบอร์และการคุ้มครอง

ข้อมูลส่วนบุคคล รวมถึง การส่งเสริมให้เกิดการพัฒนาบุคลากรด้านดังกล่าว

ตารางที่ 1 ค่าเป้าหมาย : ร้อยละของหน่วยงานที่ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง

ปีงบประมาณ 67	ปีงบประมาณ 68	ปีงบประมาณ 69	ปีงบประมาณ 70
-	ร้อยละ 100 ของ หน่วยงานผ่านเกณฑ์ฯ ระดับสูง (ตุลาคม 2567 – กันยายน 2568)	ร้อยละ 100 ของหน่วย งานผ่านเกณฑ์ฯ ระดับ สูง (ตุลาคม 2568 – กันยายน 2569)	ร้อยละ 100 ของหน่วย งานผ่านเกณฑ์ฯ ระดับ สูง (ตุลาคม 2569 – กันยายน 2569)

วัตถุประสงค์ : 1. เพื่อให้หน่วยงานมีความพร้อมรับมือเหตุการณ์ฉุกเฉินทางคอมพิวเตอร์ ด้วยระบบป้องกัน
ตรวจจับ วิเคราะห์ และโต้ตอบต่อภัยคุกคามทางไซเบอร์

2. เพื่อลดความรุนแรงของผลกระทบกรณีหน่วยงานถูกคุกคามทางไซเบอร์ที่ส่งผลต่อการให้บริการประชาชน และอาจส่งผลต่อการคุ้มครองข้อมูลส่วนบุคคล

3. เพื่อลดปัจจัยเสี่ยงของโอกาสเกิดช่องโหว่ภัยคุกคามทางไซเบอร์

4. เพื่อให้ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์ของหน่วยงาน
โครงสร้างพื้นฐานสำคัญทางสารสนเทศด้านสาธารณสุข (HealthCERT) ได้รับการประสานงานอย่างรวดเร็ว
และโต้ตอบต่อภัยคุกคามทางไซเบอร์ได้ทันเวลา

ประชากรกลุ่มเป้าหมาย : -

หน่วยงานที่เกี่ยวข้องกับตัวชี้วัดนี้ : โรงพยาบาลสังกัดสำนักงานปลัดกระทรวงสาธารณสุข ได้แก่ โรงพยาบาล
ศูนย์/ทั่วไป/ชุมชนที่เปิดให้บริการแล้ว และ สำนักงานสาธารณสุขจังหวัด และ สำนักงานเขตสุขภาพ ที่ 1-12

รูปแบบการจัดเก็บข้อมูล : (เลือกได้ 1 รูปแบบ)

☐ HDC

☐ ฐานข้อมูลกรม/ กอง/ หน่วยงาน

☐ ข้อมูลจากการตรวจราชการ

☒ อื่น ระบุ หน่วยงานส่งมาให้ ศทส.สป.สธ. ตามช่องทางที่กำหนด

ดังนี้

1) หน่วยงานดำเนินการให้ระบบเครือข่ายคอมพิวเตอร์และสารสนเทศตามเกณฑ์มาตรฐาน
ความมั่นคงปลอดภัยไซเบอร์ และประเมินตนเอง หรือให้ผู้เชี่ยวชาญที่เป็นผู้ตรวจประเมิน (หากเป็นเอกชนต้อง
มีใบรับรองมาตรฐาน)

2) หน่วยงานส่งผลยืนยันผลการประเมินพร้อมหลักฐานให้คณะกรรมการควบคุมคุณภาพการตรวจประเมินความมั่นคงปลอดภัยไซเบอร์ระดับเขตสุขภาพ (ชื่อคณะกรรมการ/คณะทำงาน แล้วแต่เขตสุขภาพจะพิจารณาอาจใช้ชื่ออื่นๆ ได้) และคณะกรรมการ/คณะทำงานส่งผลการประเมินมายัง ศทส.สป.สธ. ที่อีเมล cyberaudit@moph.go.th ทุกวันพฤหัสบดี

3) ศูนย์เทคโนโลยีสารสนเทศและการสื่อสารจะยืนยันผลการประเมินของหน่วยงานทุกศูนย์ โดยแสดงผลที่ <https://ict.moph.go.th/th/extension/1763>

ระยะเวลาการเก็บรวบรวมและตัดข้อมูล :

- ข้อมูลการตรวจราชการระดับจังหวัด ใช้ข้อมูล ณ ปัจจุบันก่อนลงพื้นที่ตรวจราชการ
- สรุปตรวจราชการรอบที่ 1 (ตุลาคม 2568 - มีนาคม 2569) : ใช้ข้อมูล ณ วันที่ 31 มีนาคม 2569
- สรุปตรวจราชการรอบที่ 2 (ตุลาคม 2568 - กรกฎาคม 2569) : ใช้ข้อมูล ณ วันที่ 31 กรกฎาคม 2569

สูตรคำนวณตัวชี้วัดเชิงปริมาณ : $(A/B) \times 100$

รายการข้อมูล 1 A = หน่วยงานผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ (CTAM+) ตามที่กำหนดครบทุกข้อ

รายการข้อมูล 2 B = 990 (หน่วยงานตามที่กำหนดไว้ในคำนิยาม)

ตัวชี้วัดนี้สามารถวัดเชิงคุณภาพได้แบบใด โปรดเลือก (สามารถเลือกได้มากกว่า 1 ข้อ)

☒ 1) เชิงคุณภาพ (ด้านผลลัพธ์)

☐ 1. การให้บริการสุขภาพ

☒ 2. กำลังคนที่ให้บริการ

☐ 3. ระบบงานและการจัดการข้อมูล

☐ 4. การเข้าถึงยาช่วยชีวิตและอุปกรณ์ฉุกเฉิน

☐ 5. การเงินการคลังด้านการให้บริการ

☒ 6. ภาวะผู้นำและธรรมาภิบาลระบบสุขภาพ

หมายเหตุ : ขอให้จัดทำเกณฑ์การประเมินผลเชิงคุณภาพ ด้านผลลัพธ์ (Outcome) ตามกรอบแนวคิด

6 Building Blocks ขององค์การอนามัยโลก (WHO) ตามตารางที่ 4

☒ 2) เชิงคุณภาพ (ด้านผลกระทบ)

☐ 1. การเข้าถึงบริการ

☐ 2. ความครอบคลุมการรักษา

☐ 3. การรักษาตามมาตรฐานคุณภาพบริการ

☐ 4. ประสิทธิภาพของการรักษา

☒ 5. ความปลอดภัยของผู้ป่วยและข้อมูล

หมายเหตุ : ขอให้จัดทำเกณฑ์การประเมินผลเชิงคุณภาพ ด้านผลกระทบ (Impact) ตามองค์การอนามัยโลก (WHO) ตามตารางที่ 6

มาตรการหลัก/กระบวนการที่สำคัญ (เฉพาะมาตรการหลัก (3-5 ข้อ) ไม่ควรนำกิจกรรมมาใส่)

1) หน่วยงานส่งบุคลากรเข้าร่วมอบรม หลักสูตรต่างๆ ที่ ศทส.สป. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ และ เสริมแรงจูงใจเพื่อรักษาคนไอทีที่มีทักษะด้านไซเบอร์ให้อยู่กับหน่วยงาน รวมถึง HealthCERT โดย ศทส.สป.สธ เป็นศูนย์กลางประสานให้ความช่วยเหลือหน่วยงานด้านไซเบอร์ ผ่านช่องทางไลน์ @health-cirt

2) มีคณะทำงานดำเนินงานความมั่นคงปลอดภัยไซเบอร์ในระดับจังหวัด ทำหน้าที่ให้ความช่วยเหลือหน่วยงานในพื้นที่ ตรวจสอบ และการรับรองได้เทียบเท่าเอกชน โดยมีคณะทำงานระดับเขตสุขภาพ เป็นเครือข่ายกำกับดูแลหน่วยงานในพื้นที่ รวมถึง ดำเนินการกำกับดูแลจากส่วนกลางโดยมีการสุ่มตรวจ (Audit) หน่วยงาน

3) ภายในจังหวัด หรือ ภายในเขตสุขภาพ สามารถดูแลกันเองได้ด้วยตัวเอง ลดการพึ่งพาหน่วยงานเอกชน โดยใช้ซอฟต์แวร์แบบ Opensource ในการดำเนินงาน รวมถึงช่วยกันต่อรองในส่วนที่จำเป็นต้องใช้งบประมาณ เช่น Firewall , Server , ค่า MA หรือ ค่าใช้จ่ายอื่นๆ เป็นต้น

ตารางที่ 2 เกณฑ์การประเมินผลเชิงปริมาณ :

วิธีการประเมินผล : เปรียบเทียบผลการดำเนินงานกับค่าเป้าหมาย

ผลการดำเนินงานเปรียบเทียบกับค่าเป้าหมาย	
รอบ 6 เดือน	รอบ 10 เดือน
1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 80	โรงพยาบาลชุมชน ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 80
2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 80	

เอกสาร/หลักฐานสนับสนุน : -

ตารางที่ 3 เกณฑ์การให้คะแนนเชิงปริมาณในแต่ละระดับ (ข้อมูล ณ วันที่ 31 กรกฎาคม 2569) ดังนี้

คะแนน	เกณฑ์ผลการดำเนินงาน
10	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 80 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 80
9	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 75 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 75
8	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 65 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 65
7	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 60 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 60
6	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 55 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 55
5	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 50 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 50
4	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 45

	2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 45
3	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 40 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 40
2	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 35 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 35
1	1. โรงพยาบาลระดับ M1, S และ A ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 30 2. สำนักงานสาธารณสุขจังหวัด และสำนักงานเขตสุขภาพ ผ่านเกณฑ์มาตรฐานความมั่นคงปลอดภัยไซเบอร์ระดับสูง ไม่น้อยกว่าร้อยละ 30

หมายเหตุ : เกณฑ์การให้คะแนนเชิงปริมาณหน่วยงานที่รับผิดชอบตัวชี้วัดเป็นผู้ออกแบบเกณฑ์ผลการดำเนินงาน แต่ละระดับ โดยระบุเกณฑ์คะแนน 1-10 เปรียบเทียบผลการดำเนินงานกับค่าเป้าหมาย

ตารางที่ 4 เกณฑ์การประเมินผลเชิงคุณภาพ ด้านผลลัพธ์ (Outcome) ตามกรอบแนวคิด 6 Building Blocks ขององค์การอนามัยโลก (WHO)

Building Block	หัวข้อการประเมิน (นำมาจากมาตรการหลัก)	เกณฑ์คุณภาพ ระดับ 1 0 – 40 คะแนน	เกณฑ์คุณภาพ ระดับ 2 41 – 55 คะแนน	เกณฑ์คุณภาพ ระดับ 3 56 – 70 คะแนน	เกณฑ์คุณภาพ ระดับ 4 71- 85 คะแนน	เกณฑ์คุณภาพ ระดับ 5 86 – 100 คะแนน	เอกสารหรือหลักฐาน ที่ใช้ประเมิน
☐ การให้บริการสุขภาพ							

☒ กำลังคนที่ให้บริการ	หน่วยงานส่งบุคลากรเข้าร่วมอบรม หลักสูตรต่างๆ ที่ ศทส.สป. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ และ เสริมแรงจูงใจเพื่อรักษาคนไอทีที่มีทักษะด้านไซเบอร์ให้อยู่กับหน่วยงาน รวมถึง HealthCERT โดย ศทส.สป.สธ เป็นศูนย์กลางประสานให้ความช่วยเหลือหน่วยงานด้านไซเบอร์ ผ่านช่องทางไลน์ @health-cirt	1. นักวิชาการคอมพิวเตอร์ หรือบุคลากรที่ได้รับมอบหมาย ให้ปฏิบัติงานด้านเทคโนโลยีสารสนเทศทุก คนในเขตสุขภาพ เข้าร่วมอบรมหลักสูตรที่เกี่ยวข้องกับด้าน Cybersecurity (online หรือ onsite) ที่ ศทส.สป.สธ. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ ภายในระยะเวลาไม่เกิน 2 ปี น้อยกว่าร้อยละ 41 (20 คะแนน) 2. ทุกจังหวัดในแต่ละเขตสุขภาพส่งผู้บริหารเข้าอบรมหลักสูตร MOPH CISO น้อยกว่าร้อยละ 41 (20 คะแนน)	1. นักวิชาการคอมพิวเตอร์ หรือบุคลากรที่ได้รับมอบหมายให้ปฏิบัติงานด้านเทคโนโลยีสารสนเทศทุก คนในเขตสุขภาพ เข้าร่วมอบรมหลักสูตรต่างๆ ที่เกี่ยวข้องกับด้าน Cybersecurity (online หรือ onsite) ที่ ศทส.สป.สธ. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ ภายในระยะเวลาไม่เกิน 2 ปี น้อยกว่าร้อยละ 41 (27.5 คะแนน) 2. ทุกจังหวัดในแต่ละเขตสุขภาพส่งผู้บริหารเข้าอบรมหลักสูตร MOPH CISO ไม่น้อยกว่าร้อยละ 41 (27.5 คะแนน)	1. นักวิชาการคอมพิวเตอร์ หรือบุคลากรที่ได้รับมอบหมายให้ปฏิบัติงานด้านเทคโนโลยีสารสนเทศทุก คนในเขตสุขภาพ เข้าร่วมอบรมหลักสูตรต่างๆ ที่เกี่ยวข้องกับด้าน Cybersecurity (online หรือ onsite) ที่ ศทส.สป.สธ. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ ภายในระยะเวลาไม่เกิน 2 ปี น้อยกว่าร้อยละ 56 (35 คะแนน) 2. ทุกจังหวัดในแต่ละเขตสุขภาพส่งผู้บริหารเข้าอบรมหลักสูตร MOPH CISO ไม่น้อยกว่าร้อยละ 56 (35 คะแนน)	1. นักวิชาการคอมพิวเตอร์ หรือบุคลากรที่ได้รับมอบหมายให้ปฏิบัติงานด้านเทคโนโลยีสารสนเทศทุก คนในเขตสุขภาพ เข้าร่วมอบรมหลักสูตรต่างๆ ที่เกี่ยวข้องกับด้าน Cybersecurity (online หรือ onsite) ที่ ศทส.สป.สธ. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ ภายในระยะเวลาไม่เกิน 2 ปี ไม่น้อยกว่าร้อยละ 71 (42.5 คะแนน) 2. ทุกจังหวัดในแต่ละเขตสุขภาพส่งผู้บริหารเข้าอบรมหลักสูตร MOPH CISO ไม่น้อยกว่าร้อยละ 71 (42.5 คะแนน)	1. นักวิชาการคอมพิวเตอร์ หรือบุคลากรที่ได้รับมอบหมายให้ปฏิบัติงานด้านเทคโนโลยีสารสนเทศทุก คนในเขตสุขภาพ เข้าร่วมอบรมหลักสูตรต่างๆ ที่เกี่ยวข้องกับด้าน Cybersecurity (online หรือ onsite) ที่ ศทส.สป.สธ. จัดขึ้น หรือหน่วยงานที่น่าเชื่อถือ ภายในระยะเวลาไม่เกิน 2 ปี ไม่น้อยกว่าร้อยละ 86 (50 คะแนน) 2. ทุกจังหวัดในแต่ละเขตสุขภาพส่งผู้บริหารเข้าอบรมหลักสูตร MOPH CISO ไม่น้อยกว่าร้อยละ 86 (50 คะแนน)	1. หลักฐานการส่งบุคลากรในหน่วยงานเข้าร่วมฝึกอบรม หรือหลักฐานการเข้าร่วมฝึกอบรมด้าน Cybersecurity 2. หลักฐานการส่งบุคลากรในหน่วยงานเข้าร่วมฝึกอบรมหลักสูตร MOPH CISO หรือหลักฐานการเข้าร่วมฝึกอบรมหลักสูตร MOPH CISO
☐ ระบบงาน และการจัดการข้อมูล							
☐ การเข้าถึงยาและเทคโนโลยี							

☐ การเงิน การคลังด้าน การให้บริการ							
☒ ภาวะ ผู้นำ และ ธรรมาภิบาล ระบบ สุขภาพ	มีคณะกรรมการดำเนินงาน ความมั่นคงปลอดภัยไซเบอร์ ในระดับจังหวัด ทำหน้าที่ให้ ความช่วยเหลือหน่วยงานใน พื้นที่ ตรวจสอบ และการ รับรองได้เทียบเท่าเอกชน โดยมีคณะกรรมการระดับเขต สุขภาพ เป็นเครือข่ายกำกับ ดูแลหน่วยงานในพื้นที่ รวม ถึง ดำเนินการกำกับดูแลจาก ส่วนกลางโดยมีการสุ่มตรวจ (Audit) หน่วยงาน	ทุกจังหวัดมี คณะกรรมการ ดำเนินงานความ มั่นคงปลอดภัย ไซเบอร์ในระดับ จังหวัด น้อยกว่า ร้อยละ 41 (40 คะแนน)	ทุกจังหวัดมี คณะกรรมการ ดำเนินงาน ความมั่นคง ปลอดภัย ไซเบอร์ใน ระดับจังหวัด ไม่น้อยกว่าร้อยละ 41 (55 คะแนน)	ทุกจังหวัดมี คณะกรรมการ ดำเนินงาน ความมั่นคง ปลอดภัย ไซเบอร์ใน ระดับจังหวัด ไม่น้อยกว่า ร้อยละ 56 (70 คะแนน)	ทุกจังหวัดมีคณะ ทำงานดำเนิน งานความมั่นคง ปลอดภัยไซเบอร์ ในระดับจังหวัด ไม่น้อยกว่าร้อยละ 71 (85 คะแนน)	1. ทุกจังหวัดมี คณะกรรมการ ดำเนินงาน ความมั่นคง ปลอดภัย ไซเบอร์ในระดับ จังหวัด ไม่น้อย กว่าร้อยละ 86 (50 คะแนน) 2. ทุกเขต สุขภาพมีคณะ ทำงานดำเนิน งานความมั่นคง ปลอดภัย ไซเบอร์ในระดับ เขตสุขภาพ ไม่ น้อยกว่าร้อยละ 86 (50 คะแนน)	หลักการแต่งตั้ง คณะกรรมการ ดำเนินงานความ มั่นคงปลอดภัย ไซเบอร์ในระดับ จังหวัด และ ระดับเขตสุขภาพ

เกณฑ์การให้คะแนนเชิงคุณภาพ ด้านผลลัพธ์

หลักการให้คะแนนเชิงคุณภาพ

- คะแนนรวม 100 คะแนนต่อหนึ่งตัวชี้วัด
 - หากตัวชี้วัดเชื่อมโยงกับหลาย Building Block (เช่น 6 ด้าน) ให้ใช้คะแนนเต็ม 100 คะแนนในการประเมินรวมทุกด้านนั้น
- คะแนนเต็มของแต่ละ Building Block = 100 คะแนน
 - หากในแต่ละด้านมีหลายหัวข้อการประเมิน ให้รวมคะแนนทุกหัวข้อในส่วนนั้นให้เท่ากับ 100 คะแนน
- คำนวณคะแนนเฉลี่ยรวมของทุกด้านที่เกี่ยวข้อง
 - เช่น $(68 + 40 + 60 + 85 + 45 + 90) \div 6 = 64.7$ คะแนน
 - เช่น $(72 + 65 + 58) \div 3 = 65$

ตารางที่ 5 การแปลผลระดับคุณภาพและระดับคะแนนการพัฒนา (5 ระดับ)

ระดับคุณภาพ	ช่วงคะแนน	การแปลผลเชิงคุณภาพ	ระดับการพัฒนา
ระดับ 5 = ดีเยี่ยม (Excellent)	86 – 100	ระบบบริการสุขภาพดีเยี่ยม เป็นแบบอย่างที่ดี ปรับปรุงต่อเนื่องอย่างเป็นระบบ	ยั่งยืนและ เป็นต้นแบบ
ระดับ 4 = ดี (Good)	71 – 85	ระบบบริการสุขภาพมีความมั่นคง ครอบคลุม และ มีการพัฒนาต่อเนื่อง	พัฒนาอย่าง มั่นคง
ระดับ 3 = พอใช้ (Fair)	56 – 70	ระบบบริการสุขภาพดำเนินการได้ตามมาตรฐาน พื้นฐาน มีบางส่วนต้องปรับปรุง	กำลังพัฒนา
ระดับ 2 = ต้อง พัฒนา (Developing)	41 – 55	ระบบบริการสุขภาพไม่มั่นคง ต้องเร่งปรับปรุงใน หลายองค์ประกอบ	ต้องการการ สนับสนุน
ระดับ 1 = ต้องเร่ง แก้ไข (Critical)	ต่ำกว่าหรือ เท่ากับ 40	ระบบบริการสุขภาพมีจุดอ่อนสำคัญ ต้องดำเนินการ การแก้ไขเร่งด่วน	ต้องการฟื้นฟู ระบบ

ตารางที่ 6 เกณฑ์การประเมินผล ด้านผลกระทบ/ ผลสำเร็จเชิงยุทธศาสตร์ ตามองค์การอนามัยโลก
(WHO)

ผล กระทบ	หัวข้อการประเมิน	เกณฑ์คุณภาพ ระดับ 1 0 – 40 คะแนน	เกณฑ์คุณภาพ ระดับ 2 41 – 55 คะแนน	เกณฑ์คุณภาพ ระดับ 3 56 – 70 คะแนน	เกณฑ์คุณภาพ ระดับ 4 71- 85 คะแนน	เกณฑ์คุณภาพ ระดับ 5 86 – 100 คะแนน	เอกสารหรือหลัก ฐาน ที่ใช้ประเมิน
☐ การเข้าถึงบริการ							
☐ ความครอบคลุม การรักษา							

☐ การรักษาตามมาตรฐานคุณภาพบริการ							
☐ ประสิทธิภาพของการรักษา							
☒ ความปลอดภัยของผู้ป่วยและข้อมูล	ภายในจังหวัด หรือภายในเขตสุขภาพสามารถดูแลกันเองได้ด้วยตัวเอง ลดการพึ่งพาหน่วยงานเอกชน โดยใช้ซอฟต์แวร์แบบ Opensource ในการดำเนินงาน รวมถึงช่วยกันต่อรองในส่วนที่จำเป็นต้องใช้งบประมาณ เช่น Firewall , Server ค่า MA หรือ ค่าใช้จ่ายอื่นๆ เป็นต้น	ภายในเขตสุขภาพ เกิดเหตุการณ์การโจมตีทางไซเบอร์แบบRansomware สำเร็จ แต่ไม่สามารถกู้คืนระบบได้ภายใน 48 ชม. (40 คะแนน)	ภายในเขตสุขภาพ เกิดเหตุการณ์การโจมตีทางไซเบอร์แบบRansomware สำเร็จ 1 ระบบ แต่สามารถกู้คืนระบบได้ภายใน 48 ชม. (55 คะแนน)	ภายในเขตสุขภาพ เกิดเหตุการณ์การโจมตีทางไซเบอร์แบบRansomware สำเร็จ มากกว่า 1 ระบบ แต่สามารถกู้คืนระบบได้ภายใน 24 ชม. (70 คะแนน)	ภายในเขตสุขภาพ เกิดเหตุการณ์การโจมตีทางไซเบอร์แบบRansomware สำเร็จ 1 ระบบ แต่สามารถกู้คืนระบบได้ภายใน 24 ชม. (85 คะแนน)	ทุกหน่วยงานในเขตสุขภาพ (รพช. รพท. รพศ. สสจ. สำนักงานเขตสุขภาพ) ไม่เกิดเหตุการณ์การโจมตีทางไซเบอร์แบบRansomware สำเร็จ (100 คะแนน)	หลักฐาน Log จาก Firewall, SEIM, XDR/EDR, หรืออื่นๆ ที่เกี่ยวข้อง

เกณฑ์การประเมินผลกระทบ/ผลสำเร็จเชิงยุทธศาสตร์

หลักการให้คะแนน

1) คะแนนรวม 100 คะแนนต่อหนึ่งตัวชี้วัด

- หากตัวชี้วัดเชื่อมโยงกับ Result มากกว่า 1 ด้าน (เช่น 3 ด้าน) ให้ใช้คะแนนเต็ม 100 คะแนนในการประเมินรวมทุกด้านนั้น
- คำนวณคะแนนเฉลี่ยรวม เช่น $(75+85+69) \div 3 = 76.33$ คะแนน
เช่น $(68+85+75+55+64.6) \div 3 = 69.5$ คะแนน
ใช้คะแนนเฉลี่ยดังกล่าวเป็นคะแนนรวมของ Result

2) พิจารณาจากผลลัพธ์เชิงประจักษ์ (Evidence of Result)

- ใช้ข้อมูลเชิงประจักษ์ เช่น สถิติ ผลสำรวจ ข้อมูลคุณภาพบริการ และผลการเปลี่ยนแปลงต่อประชาชน
- เน้นการสะท้อนผลลัพธ์ (Results-based) มากกว่ากระบวนการดำเนินงาน

3) พิจารณาจากผลลัพธ์เชิงประจักษ์ (Evidence of Result)

- ใช้ข้อมูลเชิงประจักษ์ เช่น สถิติ ผลสำรวจ ข้อมูลคุณภาพบริการ และผลการเปลี่ยนแปลงต่อประชาชน
- มีแนวโน้มการพัฒนายอย่างต่อเนื่องหรือไม่
- ส่งผลกระทบเชิงบวกต่อระบบสุขภาพและประชาชนหรือไม่

ตารางที่ 7 การแปลผลคะแนนเพื่อสะท้อนระดับคุณภาพและระดับคะแนนของผลกระทบ

ระดับคุณภาพ	ช่วงคะแนน	ความหมายโดยสรุป
ระดับ 5 = ดีเยี่ยม (Excellent)	86 – 100	ผลลัพธ์โดดเด่น สร้างผลกระทบเชิงบวกต่อประชาชนและระบบบริการสาธารณสุขอย่างยั่งยืน
ระดับ 4 = ดี (Good)	71 – 85	ผลลัพธ์บรรลุเป้าหมายชัดเจน สร้างผลกระทบเชิงบวกต่อประชาชน แต่ควรพัฒนาระบบบริการสุขภาพอย่างต่อเนื่อง
ระดับ 3 = พอใช้ (Fair)	56 – 70	ผลลัพธ์อยู่ในระดับมาตรฐาน มีระบบบริการสุขภาพบางส่วนต้องปรับปรุง
ระดับ 2 = ต้องพัฒนา (Developing)	41 – 55	ผลลัพธ์ยังไม่บรรลุเป้าหมาย ต้องปรับกลยุทธ์หรือระบบสนับสนุน
ระดับ 1 = ต้องเร่งแก้ไข (Critical)	ต่ำกว่าหรือเท่ากับ 40	ผลลัพธ์ไม่เป็นไปตามเป้าหมาย หรือเกิดผลกระทบในทางลบต่อประชาชนและระบบบริการสุขภาพ ต้องแก้ไขเร่งด่วน

หลักการคิดสัดส่วนผลสัมฤทธิ์ของการประเมินตัวชี้วัดการตรวจราชการ คิดอัตราส่วน 70 : 30

- สัดส่วน 70 คือ ผลสัมฤทธิ์เชิงปริมาณ
- สัดส่วน 30 คือ ผลสัมฤทธิ์เชิงคุณภาพ (Outcome หรือ Impact)

ตารางที่ 10 การคำนวณคะแนนผลการประเมินตัวชี้วัดการตรวจราชการ คิดอัตราส่วน 70 : 30

ระดับคะแนนเชิงปริมาณ (70%)	ระดับคะแนนเชิงคุณภาพ ด้านผลลัพธ์ (15%)	ระดับคะแนนเชิงคุณภาพ ด้านผลกระทบ (15%)
ระดับคะแนนที่ได้ $\times 0.7 =$ Score	(คะแนนที่ได้ $\div 10$) $\times 0.15$ = Score	(คะแนนที่ได้ $\div 10$) $\times 0.15$ = Score
Score เชิงปริมาณ + Score เชิงคุณภาพ = (คะแนนเต็ม 10)		

หมายเหตุ : 1. หากตัวชี้วัดประเมินเชิงคุณภาพด้านผลลัพธ์ ให้ใส่คะแนนตามช่องที่กำหนดและคำนวณ Score

2. หากตัวชี้วัดประเมินเชิงคุณภาพด้านผลกระทบ ให้ใส่คะแนนตามช่องที่กำหนดและคำนวณ

Score

3. หากตัวชี้วัดประเมินได้เพียงด้านเดียว(ด้านผลลัพธ์หรือด้านผลกระทบ) ให้คิดสัดส่วน

เชิงคุณภาพด้านเดียวเท่ากับ 30% เช่น (คะแนนที่ได้ $\div 10$) $\times 0.3 =$ Score

หน่วยงานที่รับผิดชอบหลัก : สำนักงานปลัดกระทรวงสาธารณสุข ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร



ศูนย์เทคโนโลยีสารสนเทศและการสื่อสาร สำนักงานปลัดกระทรวงสาธารณสุข